

The Case for Agent Authority Infrastructure

Why AI agents need authority before action and evidence after action

This paper is the source version of the NeoXFortress manifesto.

Canonical web version:

<https://neoxfortress.com/manifesto>

Abstract

AI-agent deployments in high-trust environments face an evidence gap. Existing tools may record what an agent did, but often do not clearly show what the agent was authorized to do, what was denied, what required human review, and what evidence exists afterward.

Agent Authority Infrastructure is proposed as a runtime authority, approval, and tamper-evident evidence layer for AI agents. It sits between agent intent and tool execution, resolves intended actions as allow, deny, or human review, and produces action-level evidence for security review, audit, and closeout.

Core Claim

AI agents in high-trust environments require authority before action and evidence after action.

Citation

DOI pending Zenodo publication.

Definition

Canonical Definition

Agent Authority Infrastructure (AAI) is the runtime authority, approval, and tamper-evident evidence layer for AI agents.

AAI defines what an AI agent is allowed to do before execution, enforces allow / deny / human-review decisions at runtime, and preserves verifiable evidence after each action.

Short Definition

Agent Authority Infrastructure decides what AI agents are allowed to do, enforces the decision before execution, and produces evidence afterward.

Expanded Definition

AAI is a security and governance layer that sits between AI-agent intent and tool execution. It consumes identity, mission scope, policy, and context; evaluates whether a proposed action is authorized; routes the action to allow, deny, or human review; and records the decision as signed, tamper-evident evidence.

AAI is useful when an organization needs to answer reviewer questions such as:

- Which agent attempted the action?
- What mission or workflow was the agent operating under?
- Which tool or resource did the agent attempt to use?
- Was the action allowed, denied, or escalated?
- Which policy version governed the decision?
- Who approved the action if human review was required?
- What evidence exists after the action?

Tagline

Authority before action. Proof after action.

In body copy, prefer "evidence" over "proof." The tagline keeps "proof" because it is memorable and plain-language.

Audience

This framework is written for:

- Federal AI program leaders
- Authorizing Officials
- ISSOs and ISSMs
- RMF and ATO reviewers
- Federal systems integrators
- Defense and regulated AI teams
- Security architects
- GRC and audit teams
- AI platform teams deploying agents into high-trust workflows

The Framework: Authority, Approval, Evidence

Agent Authority Infrastructure is built on three primitives: authority, approval, and evidence.

Authority

Authority is the explicit definition of what an AI agent is allowed to do.

Authority should be expressed at the level of action, not only at the level of model output or user role. It should account for:

- Agent identity
- Mission scope
- Tool boundary
- Data boundary
- User or system context
- Conditions and constraints
- Time or duration
- Human-review requirements
- Revocation and policy update path

Federal Example

An RMF support agent may be authorized to read approved SSP source documents, draft control narrative updates, and generate an evidence summary for reviewer inspection.

It may not be authorized to access unrelated repositories, email the package externally, edit authoritative records, or call tools outside its mission boundary.

Approval

Approval is the runtime decision that determines whether an intended action is allowed to execute.

Approval is not a model recommendation. The model may propose an action. A separate authority layer should evaluate that action against policy and return one of three outcomes:

- Allow
- Deny
- Human review

The separation matters. If the same model that recommends an action is treated as the system that authorized it, the deployment has no independent action boundary.

Federal Example

An agent attempts to send a compliance package to an external recipient. The policy says external transmission requires named reviewer approval. The action is held, routed to review, and released only if the reviewer approves.

Evidence

Evidence is the signed, tamper-evident record of the approval decision.

Evidence should help reviewers reconstruct what happened and what was prevented from happening. It should describe:

- Agent identifier
- Mission identifier
- Requested action
- Target tool or resource
- Policy version
- Decision outcome
- Human reviewer context, if applicable
- Timestamp
- Verification status

Evidence is not the same as ordinary logging. Logs are useful for observability. Evidence is structured for review, verification, and accountability.

Federal Example

At pilot closeout, an AO receives an evidence pack showing allowed actions, denied actions, escalated actions, approvals, policy versions, and verification status for the pilot period.

Summary

The model generates a recommendation. The authority layer decides whether the action is allowed to execute. The evidence layer preserves what happened afterward.

Reference Architecture

Agent Authority Infrastructure can be represented as a five-layer stack.

Layer 1: User / Mission

The starting point is the mission context. This includes the human, program, system, or workflow that tasks the agent and defines what the agent is supposed to accomplish.

Layer 2: Agent Runtime

The agent runtime includes the model, orchestration framework, reasoning loop, prompts, tools interface, and framework-specific execution context.

Examples include LangChain, AutoGen, CrewAI, model-provider tool-calling flows, and custom runtimes.

Layer 3: Agent Authority Layer

The Agent Authority Layer is where AAI lives.

Core components:

- Agent Registry
- Policy Engine
- Decision Gate
- Human Review Path
- Receipt Generator

This layer evaluates agent intent before tool execution and produces evidence after each decision.

Layer 4: Tools / Actions

The tools and actions layer contains the APIs, databases, filesystems, message queues, external services, and operational systems that the agent may attempt to use.

Layer 5: Evidence & Audit Plane

The evidence and audit plane contains signed action receipts, hash-chained ledger entries, evidence packs, and exports for SIEM, GRC, RMF, audit, and closeout review.

Architecture Diagram

![[Agent Authority Infrastructure reference architecture](../architecture/reference-architecture.svg)]

Design Principle

AAI should sit underneath the agent framework, beside model evaluation and red-teaming, and upstream of SIEM, GRC, RMF, and audit systems.

It should not replace those systems. It should produce evidence those systems can consume.

What Agent Authority Infrastructure Is Not

Clear boundaries make the category more useful.

Not a Guardrail

Guardrails filter model inputs and outputs. AAI governs the actions that follow from model output.

A guardrail might detect unsafe generated text. AAI decides whether the agent is allowed to call a tool, access a resource, or take an external action.

Not a Model Risk Platform

Model risk management platforms govern models across registration, validation, monitoring, and retirement.

AAI governs runtime actions. It can feed action-level evidence into model risk workflows, but it does not replace them.

Not a SIEM

SIEMs aggregate and correlate logs.

AAI produces signed, action-level records that a SIEM can ingest. AAI is upstream of the SIEM, not a replacement for it.

Not Red-Teaming

Red-teaming tests model behavior, failure modes, and adversarial prompts.

AAI governs whether an intended action is allowed to execute at runtime. A model can pass evaluation and still attempt an unauthorized action.

Not an Agent Framework

Agent frameworks help teams build agents.

AAI should be framework-agnostic. It should sit between the agent runtime and tools, regardless of whether the agent uses LangChain, AutoGen, CrewAI, model-provider tool calling, or a custom runtime.

Not an Identity Provider

Identity providers answer who the user, service, or agent is.

AAI consumes identity and answers a different question: what is this agent allowed to do right now?

Policy Context

Agent Authority Infrastructure is not a substitute for legal, compliance, RMF, or ATO review. It is a framework for producing better action-level evidence for those processes.

OMB AI Guidance

Recent OMB AI guidance pushes federal agencies to accelerate AI use while maintaining governance, risk management, acquisition discipline, and public trust.

AAI is relevant because agentic workflows introduce action-level questions that model documentation and ordinary system logs may not answer:

- What was the agent authorized to do?
- What decision was made before execution?
- What evidence exists after execution?
- What was denied or escalated?

NIST AI RMF

The NIST AI Risk Management Framework emphasizes governance, mapping, measurement, and management of AI risks.

AAI can support AI RMF-aligned narratives by producing evidence related to runtime controls, action boundaries, accountability, and monitoring.

NIST AI Agent Work

NIST has moved directly into AI-agent security, identity, authorization, and interoperability questions. AAI is positioned as a practical framework for the action boundary those conversations require.

RMF / ATO Review

AAI does not grant an authorization, replace an Authorizing Official, or certify a system.

AAI can help produce evidence that supports security review and RMF/ATO readiness:

- Policy definition
- Runtime decision records
- Denied-action evidence
- Human-review records
- Signed receipt verification
- Closeout evidence packs

Buyer-Safe Claim

AAI supports security-review and RMF/ATO readiness. It does not claim customer authorization, FedRAMP authorization, FIPS validation, or agency approval.

FAQ

What is Agent Authority Infrastructure?

Agent Authority Infrastructure is the runtime authority, approval, and tamper-evident evidence layer for AI agents.

How is AAI different from guardrails?

Guardrails filter model inputs and outputs. AAI governs the actions an agent attempts to take after the model produces output.

How is AAI different from a SIEM?

A SIEM aggregates and correlates logs. AAI produces signed, action-level evidence that a SIEM can ingest.

How does AAI relate to NIST AI RMF?

AAI can support AI RMF-aligned governance and risk narratives by producing runtime evidence for authority, approval, monitoring, and accountability.

Does AAI replace RMF or ATO review?

No. AAI does not grant an authorization or replace an Authorizing Official. It can support security-review and RMF/ATO readiness by producing better evidence.

What does an AAI evidence pack include?

An evidence pack may include policy context, allowed actions, denied actions, escalated actions, human-review decisions, receipt verification status, and closeout summaries.

Is AAI compatible with LangChain, AutoGen, CrewAI, and custom agents?

The framework is intended to be framework-agnostic. AAI should sit between the agent runtime and tools.

Who needs AAI?

Teams deploying AI agents in high-trust environments where security, compliance, mission, audit, or operational reviewers need evidence of bounded action.

Is this open source?

This repository is public framework documentation. It is not the NeoXFortress Gateway product implementation.

Why use the phrase "authority" instead of only "authorization"?

"Authorization" often sounds like IAM, RBAC, or token validation. "Authority" is broader: mission scope, policy, tool boundary, human review, and evidence.